

DATA ECOSYSTEMS AND GOVERNANCE IN
ORGANIZATIONS (2606)

NOVACRED – CREDIT APPLICATION GOVERNANCE ANALYSIS

GROUP 3C

08.03.2026

THE AUDIT BRIEF

Context

NovaCred is a fintech lender under regulatory scrutiny for potential discrimination in its credit approval process.

Dataset

502 raw credit applications in nested JSON format, covering financial profiles, demographics, spending behaviour, and algorithmic decisions.

Objective

Audit the dataset for data quality, algorithmic bias, and GDPR / EU AI Act compliance. Produce governance recommendations grounded in evidence.

1

Data Quality

Completeness, consistency, validity, uniqueness

2

Bias Analysis

Disparate impact, proxy discrimination, fairness metrics

3

Privacy & Governance

GDPR gaps, EU AI Act classification, recommendations

4

Conclusion

Key findings

MEET THE TEAM



Robert Connor
Brown

75628

DATA ENGINEER



Madalena Susan
Rocha

72541

DATA SCIENTIST



António Marques
dos Santos

71212

GOVERNANCE OFFICER

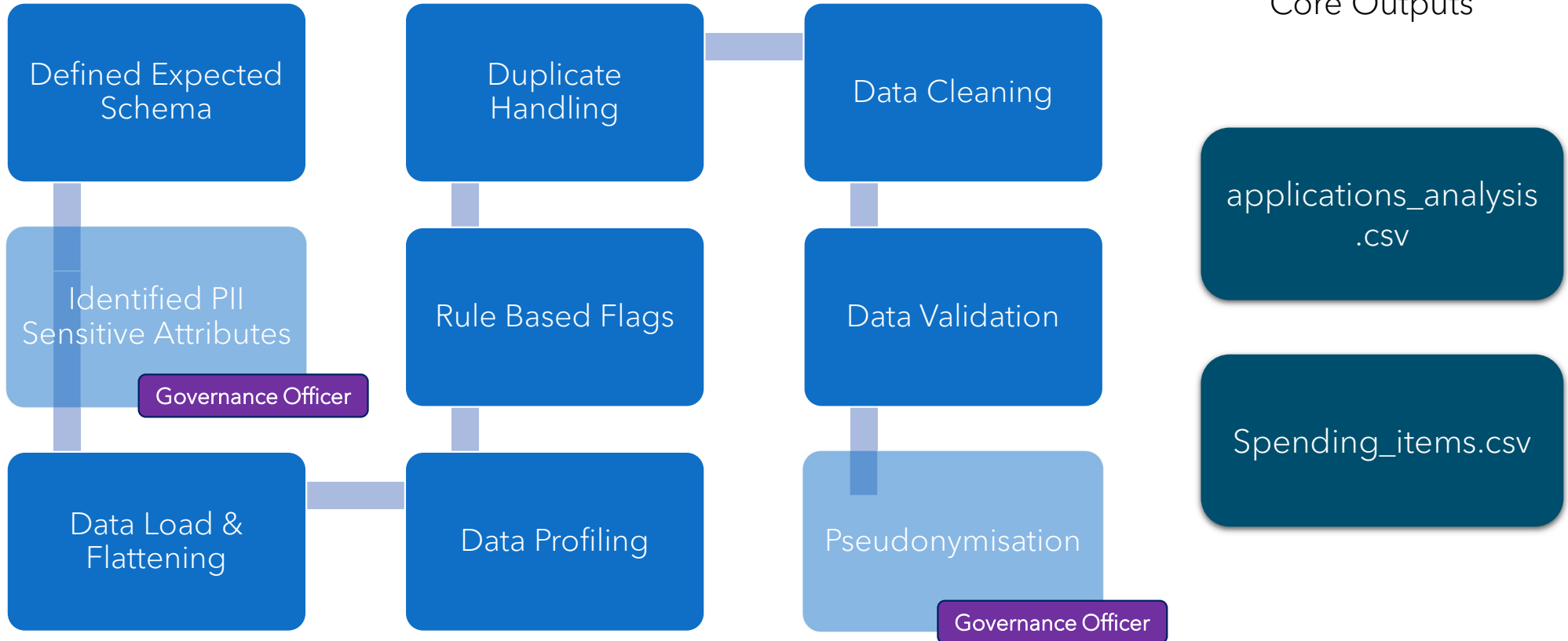


Nora
Puchert

73020

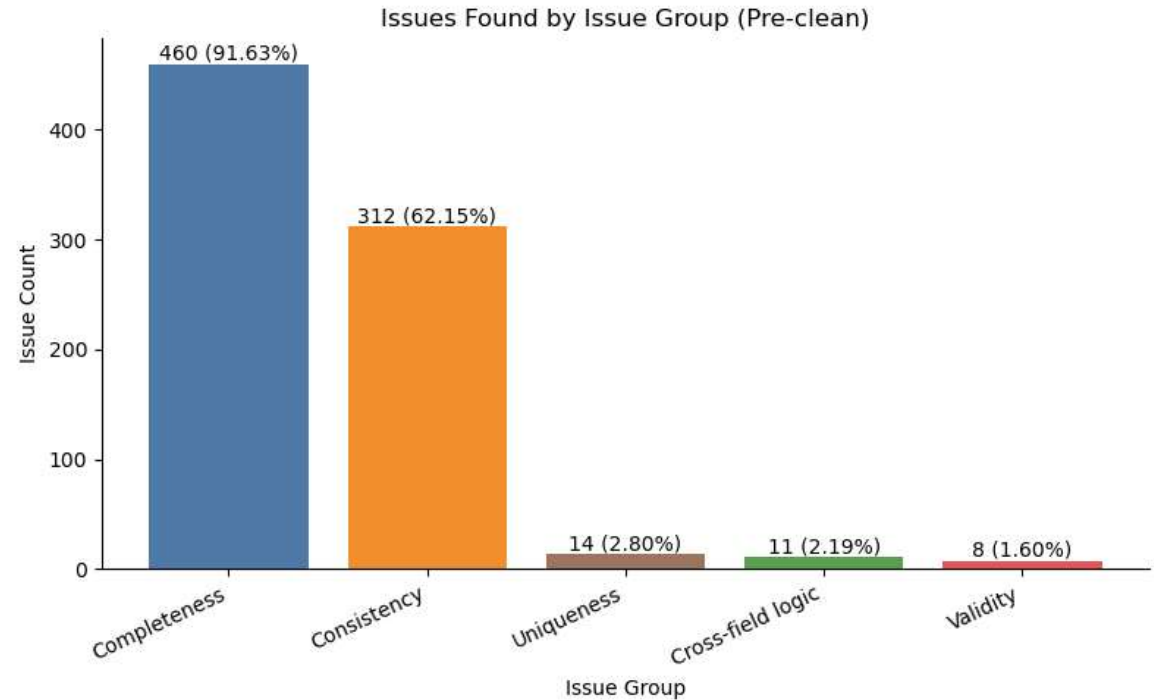
PRODUCT LEAD

DATA QUALITY PROCESS

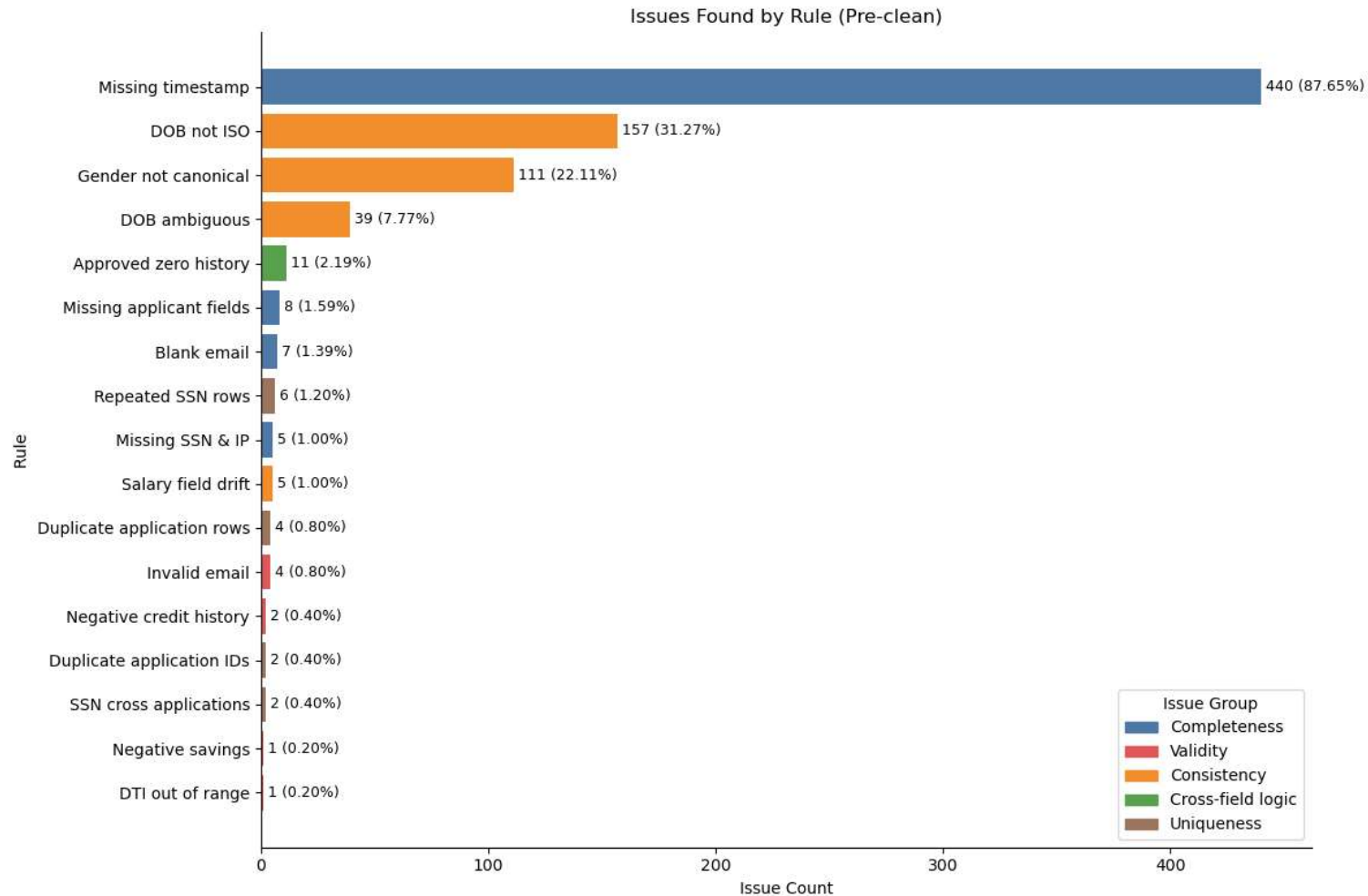


DATA QUALITY: FINDING

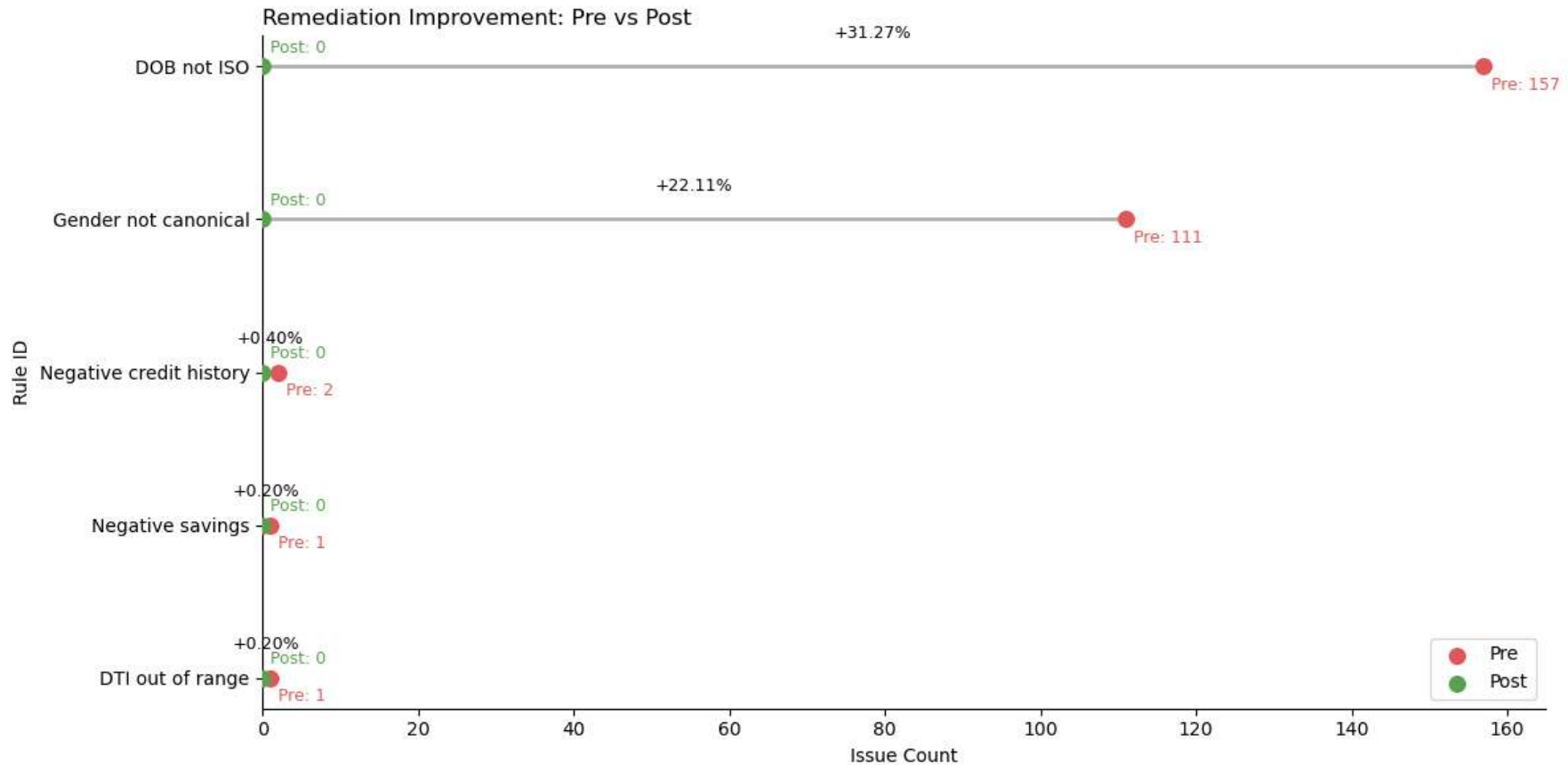
Issue Group	Definition
Completeness	Data required for business or regulatory purposes is missing/blank.
Consistency	Data is present but not stored in a standard, canonical, or expected representation.
Cross-field logic	Data fields are individually valid but logically inconsistent when evaluated together.
Validity	Data values violate defined business rules, formats, or allowable ranges.
Uniqueness	Records or identifiers that should be distinct appear more than once.



DATA QUALITY: FINDING



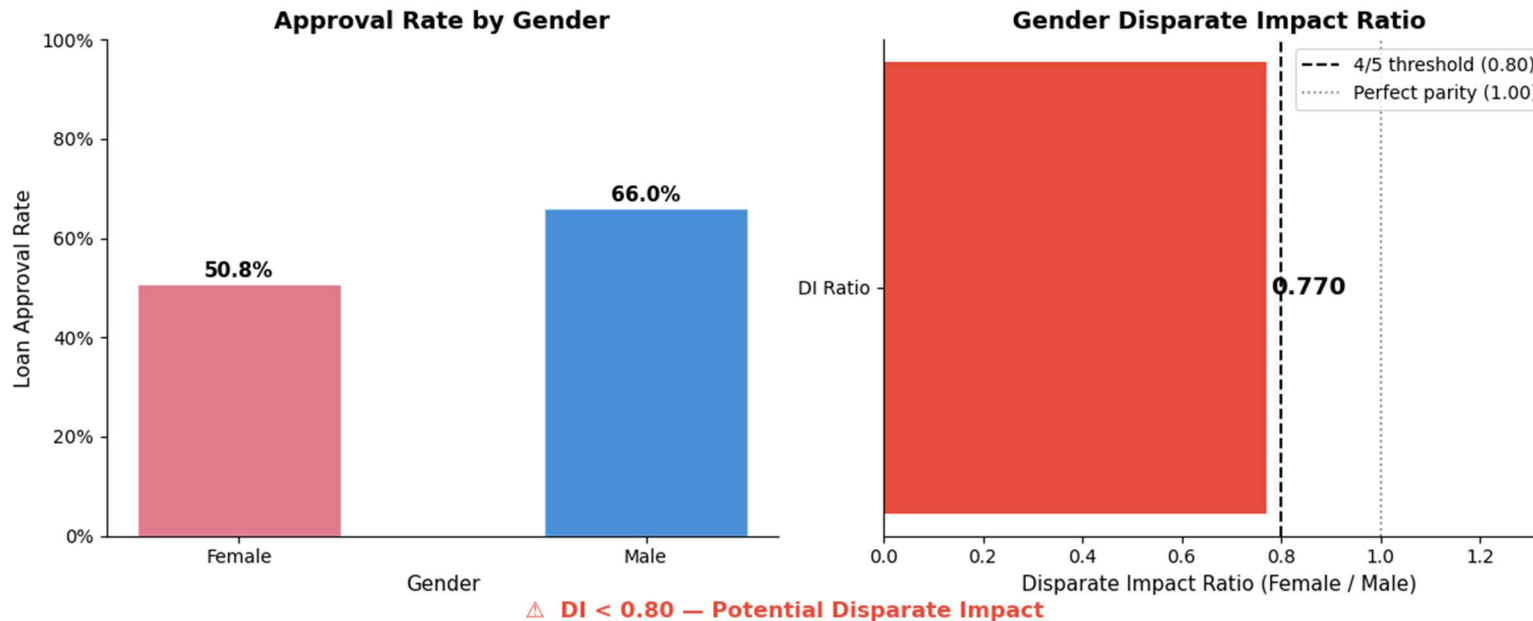
DATA QUALITY: HANDLING



DATA QUALITY: HANDLING

application_id	Count	Issue Type	Solution
app_001	2	conflict	'Duplicate Entry' removed
app_042	2	versioned	Selected row with the latest timestamp. If Nan, selected first

BIAS ANALYSIS: GENDER DISPARATE IMPACT

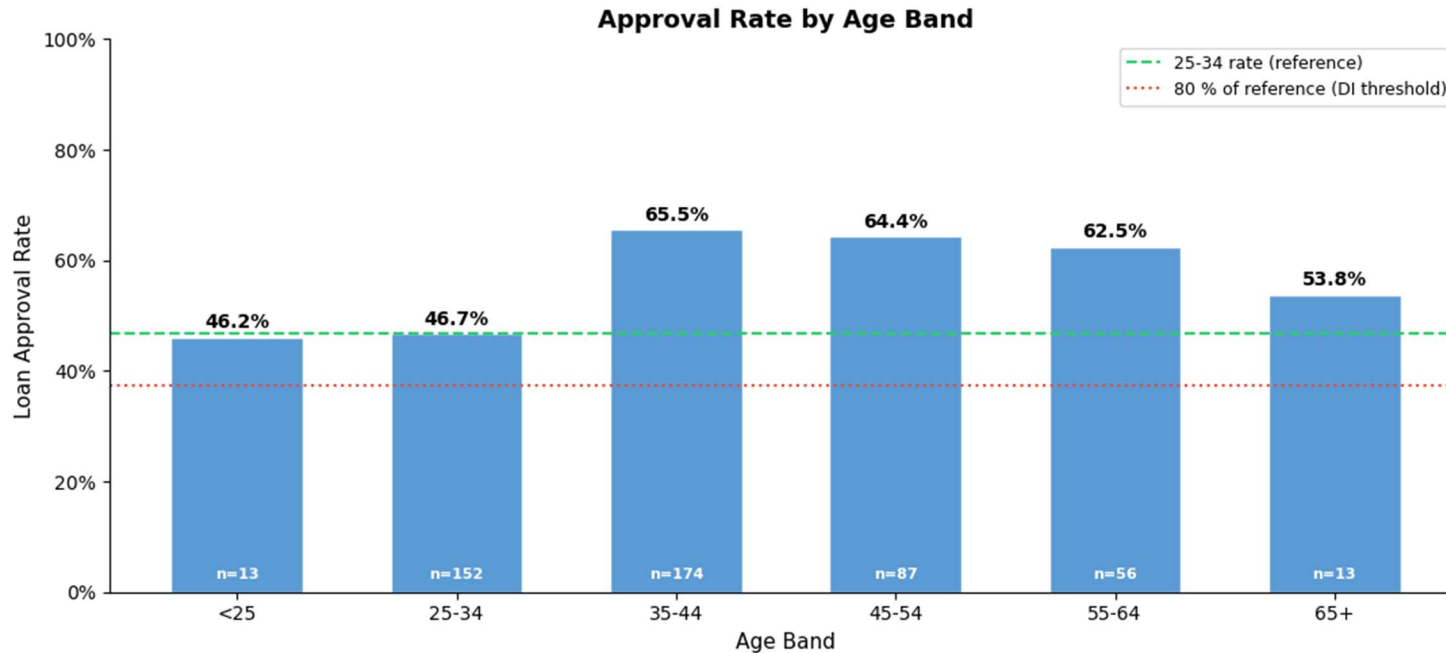


DI = 0.77 flags for four-fifths rule

Chi-squared test p-value of 0.0008 means this result is significant

Conclusion: There is significant evidence that female applicants are approved less frequently than male applicants

BIAS ANALYSIS: AGE-BASED BIAS PATTERNS



25-34 band used as privileged group ("prime" working age)

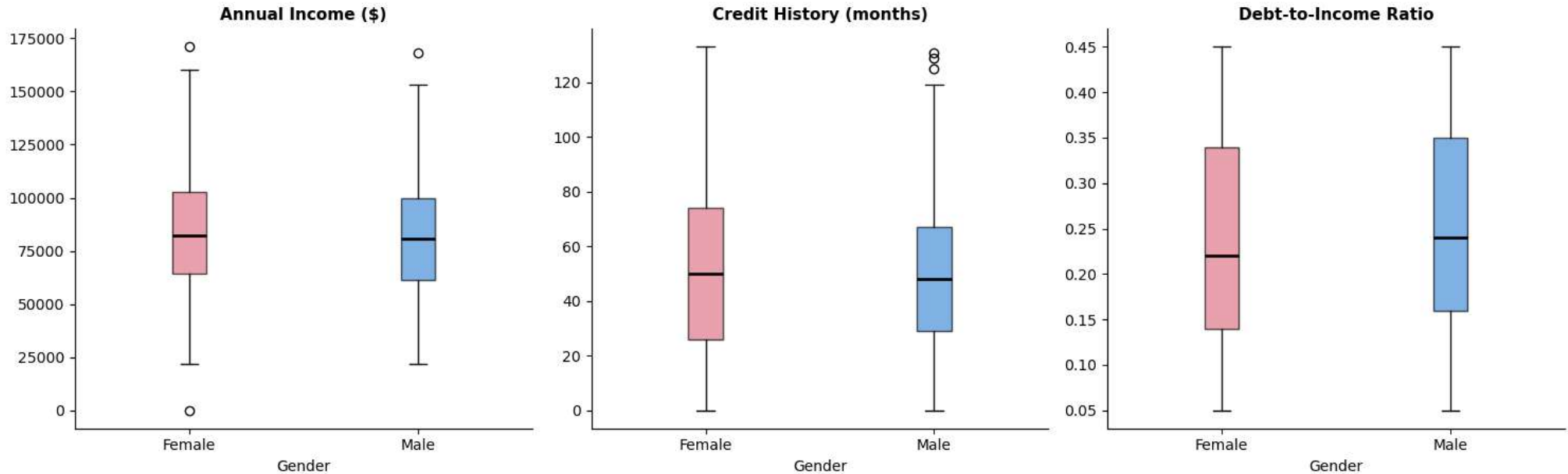
No band flags for four-fifths rule

Chi-squared test p-value of 0.0115 means this result is significant

Conclusion: There is no evidence that other age bands are approved less frequently than 25-34 band

BIAS ANALYSIS: PROXY DISCRIMINATION – FINANCIAL FEATURES

Financial Feature Distribution by Gender (Proxy Check)



No financial features appear to have different distributions across genders

Credit history correlates strongly with age

Conclusion: No financial features appear to introduce proxy bias by gender, but if the algorithm used weighs credit history length heavily, this would incur an age-based bias

BIAS ANALYSIS: PROXY DISCRIMINATION - SPENDING

Average monthly spending by category and gender:

category_clean	Adult Entertainment	Alcohol	Dining	Education	\
clean_gender					
Female	322.0000	644.6700	464.1600	507.4900	
Male	658.5000	414.2500	480.4300	488.9300	

category_clean	Entertainment	Fitness	Gambling	Groceries	Healthcare	\
clean_gender						
Female	510.3100	411.8200	408.1700	499.9600	452.8400	
Male	466.5300	490.8000	0.0000	479.1800	449.6100	

The largest spending gaps by gender are in Adult Entertainment and Gambling

Conclusion: If the algorithm used by NovaCred heavily penalizes spending in these categories, this would introduce a gender bias by proxy

BIAS ANALYSIS: REJECTION REASON

Top 5 rejection reasons – crosstab by gender:

clean_gender	Female	Male
clean_rejection_reason		
algorithm_risk_score	100	69
high_dti_ratio	7	4
insufficient_credit_history	15	8
low_income	1	3

A Chi-Squared test revealed no significant difference between female and male clients for rejection reason

82% of rejections are attributed to "algorithmic risk" which is a concern for auditability

Conclusion: The majority of rejections being for "algorithmic risk" imposes a large auditability risk, as it cannot be traced to any specific evaluation criteria without knowing the algorithm

PRIVACY & GOVERNANCE

Governance Audit Pipeline → 5 Evidence Files



pii_governance_evidence.csv | ropa.csv | gdpr_gap_report.csv | breach_exposure_assessment.csv | governance_recommendations.csv

PRIVACY & GOVERNANCE

PII INVENTORY

field_path	classification	gdpr_category	gdpr_article	risk
applicant_info.full_name	Direct PII	Personal data	Art. 4(1), Art. 5(1)(c)	High
applicant_info.email	Direct PII	Personal data	Art. 4(1), Art. 5(1)(c)	High
applicant_info.ssn	Direct PII	Personal data (national identifier equivalent)	Art. 4(1), Art. 5(1)(c), Art. 32	Critical
applicant_info.ip_address	Direct PII	Online identifier — personal data per GDPR recital 30	Art. 4(1), Art. 5(1)(c)	High
applicant_info.date_of_birth	Direct PII	Personal data	Art. 4(1), Art. 5(1)(c)	High
applicant_info.gender	Quasi-PII	Personal data	Art. 5(1)(c)	Medium
applicant_info.zip_code	Quasi-PII	Personal data (location proxy)	Art. 5(1)(c)	Medium
spending_behavior[].category + amount	Behavioural data	Personal data — behavioural profiling	Art. 5(1)(b), Art. 22	High
decision.loan_approved + interest_rate	Decision output	Automated decision affecting data subject	Art. 22, Art. 13	Critical

- 5 Direct PII fields identified: full name, email, SSN, IP address, date of birth
- SSN classified as **Critical** risk – stored in plain text, violating GDPR Art. 25
- ZIP code flagged as ethnic proxy risk under GDPR Art. 9

Conclusion: Analysis layer is PII-safe (pseudonymisation applied) – curated layer retains PII for audit only

PRIVACY & GOVERNANCE

GDPR GAP ANALYSIS

gap_id	gap_name	field	status	gdpr_article	severity
GAP-001	Missing consent timestamp	consent_timestamp	Absent from dataset	Art. 6, Art. 7	Critical
GAP-005	No audit trail for automated decisions	decision_audit_log	Absent from dataset	Art. 22, Art. 13	Critical
GAP-006	SSN stored unencrypted	applicant_info.ssn	Absent from dataset	Art. 25, Art. 32	Critical
GAP-002	Missing data retention policy	retention_until	Absent from dataset	Art. 5(1)(e)	High
GAP-004	Missing processing purpose field	processing_purpose	Absent from dataset	Art. 5(1)(b)	High
GAP-003	Missing data source / transparency field	data_source	Absent from dataset	Art. 14	High
GAP-007	No human oversight documentation	human_review_flag	Absent from dataset	Art. 22, Art. 14 (AI Act)	High
GAP-008	Sensitive behavioural data collected without explicit purpose	spending_behavior	Absent from dataset	Art. 5(1)(b), Art. 22	Medium

8 gaps identified: 3 Critical, 4 High, 1 Medium – all fields absent from all 502 records

- **GAP-001:** No consent_timestamp – NovaCred cannot prove lawful basis for any application (Art. 6)
- **GAP-005:** 81.2% of rejections cite only algorithm_risk_score – no audit trail (Art. 22)
- **GAP-006:** SSNs stored unencrypted (Art. 34)

PRIVACY & GOVERNANCE

EU AI ACT CLASSIFICATION

System : NovaCred Automated Credit Scoring System
Risk Level : HIGH-RISK
Legal Basis : EU AI Act Annex III, Point 5(b) – Creditworthiness assessment and credit scoring

	article	obligation	description
0	Art. 9	Risk management system	Implement and maintain a risk management system throughout the entire lifecycle of the AI system. Identify and analy...
1	Art. 10	Data governance	Training, validation, and testing data must meet quality criteria. Data must be examined for biases. Data gaps and s...
2	Art. 13	Transparency	The AI system must be sufficiently transparent to enable deployers to interpret its output. A technical document mus...
3	Art. 14	Human oversight	High-risk AI systems must be designed to allow effective human oversight. Humans must be able to intervene, override...
4	Art. 26	Deployer obligations	NovaCred (as deployer) must ensure the system is used in accordance with instructions, monitor operation, and inform...
5	Art. 72	EU database registration	High-risk AI systems in scope of Annex III must be registered in the EU database before being placed on the market o...
6	Art. 35 (GDPR)	DPIA required	Automated credit decisions using profiling likely require a Data Protection Impact Assessment under GDPR Art. 35 bef...

- **HIGH-RISK** under Annex III 5(b) – creditworthiness assessment of natural persons
- 7 obligations triggered – 5 show no compliance evidence (no DPIA, no registration, no oversight)
- Dual compliance: GDPR Art. 22 and EU AI Act Art. 13/14 both require explanation + human oversight

PRIVACY & GOVERNANCE RECOMMENDATIONS

Priority	Control	Action	Why Urgent
1	GOV-001	Implement consent tracking	Cannot prove lawful basis — all processing at legal risk
2	GOV-003	Encrypt & pseudonymise SSNs	Critical breach risk; pipeline already ready
3	GOV-004	Add human oversight mechanism	Required by GDPR Art. 22 and EU AI Act Art. 14

- 10 controls span: Legal Compliance, Security, AI Act / Automated Decisions, Fairness, Transparency, Privacy by Design
- GOV-003 (encrypt SSNs) is **Low effort**

Conclusion: NovaCred has the technical foundation – pseudonymisation is in place; what is missing is the governance layer on top of it

CONCLUSION

A SYSTEM THAT CANNOT EXPLAIN ITSELF

87.7%

Data Quality

of records missing
processing timestamp –
audit trail largely absent

0.77

Disparate Impact

gender gap below four-
fifths threshold,
statistically significant

8

GDPR Gaps

3 critical – no consent,
unencrypted SSNs, no
decision audit trail

**HIGH
RISK**

EU AI Act

Annex III §5(b) – 5 of
7 obligations unmet

Key finding across all three areas:

81.6% of all rejections cite only **algorithm_risk_score** as the rejection reason. A gender disparity is confirmed, but the system provides no mechanism to explain or investigate it: a violation of GDPR Art. 22 and EU AI Act Art. 13.

10 governance controls proposed. Immediate priorities: consent capture (GOV-001), SSN encryption (GOV-003), human oversight mechanism (GOV-004).

APPENDIX - DQ

Rule ID	Short Label	Issue Group	How Handled	Flag / Rule Logic	Transformed	Example application_ids	Example Raw Values	Example Clean Values	What Changed
R_APP_008	DOB not ISO	Consistency	Parsed multiple date formats; converted to YYYY-MM-DD; flagged ambiguity separately	DOB not matching <code>^\\d{4}-\\d{2}-\\d{2}\$</code>	100%	app_005, app_021, app_088	"03/07/1985", "1985/07/03"	"1985-07-03"	Non-standard DOB formats were normalised to ISO format.
R_APP_006	Gender not canonical	Consistency	Standardised gender values using mapping (m/f → Male/Female)	Gender not in canonical set {"Male", "Female"}	100%	app_014, app_067, app_102	"m", "F", "female "	"Male", "Female"	Variations and casing were standardised to canonical labels.
R_APP_012	Negative credit history	Validity	Coerced numeric; nullified values < 0	<code>credit_history_months < 0</code>	100%	app_043, app_118	-10, -3	NaN	Invalid negative credit history values were nullified.
R_APP_013	Negative savings	Validity	Coerced numeric; nullified values < 0	<code>savings_balance < 0</code>	100%	app_072	-500	NaN	Negative savings were treated as invalid and removed.
R_APP_014	DTI out of range	Validity	Coerced numeric; nullified values outside [0,1]	<code>debt_to_income < 0 or > 1</code>	100%	app_091	1.7	NaN	Debt-to-income values outside valid bounds were nullified.